



First Hawaiian Bank.

ENTERPRISE THIRD-PARTY RISK MANAGEMENT STANDARD PROCEDURES

STANDARD PROCEDURE NUMBER:	1053.00
STANDARD PROCEDURE OWNER:	Enterprise Technology Management
STANDARD PROCEDURE EFFECTIVE DATE:	March 1, 2018
LAST MODIFIED:	December 30, 2025
LAST REVIEWED:	December 30, 2025
FREQUENCY OF REVIEW:	Annual

PROCEDURE OVERVIEW

To ensure that First Hawaiian Inc. and First Hawaiian Bank (FHB or Bank) (collectively known as FHI or the Company) is able to fulfill its fiduciary responsibilities, it is critical that all employees and affiliates comply with FHI's Enterprise Third-Party Risk Management Standard Procedures ("Procedures").

TABLE OF CONTENTS

1.	Overview	3
2.	Risk Rating Tiers	3
3.	Third-Party Review/Contacts	3
4.	ETRM System of Record.....	3
5.	Exempt Third Parties	4
6.	Third-Party Lifecycle	4
7.	Phase 1: Due Diligence	5
8.	Phase 2: Contracting	6
9.	Phase 3: Monitoring	8
10.	Phase 4: Termination.....	10
11.	Additional Requirements for Third parties Who Are Individuals	10
12.	Third-Party Manager Approval of Payments to Third Parties; Emergencies.....	11
13.	Documentation and Retention of Documents	11
14.	Confidentiality.....	11
15.	Procedural Compliance Monitoring.....	11
16.	Exceptions	11
	List of Exhibits	11
	SUMMARY OF REVISIONS	11

Enterprise Third-Party Risk Management Procedures

1. Overview

These Procedures are provided to ensure compliance with the FHI Third-Party Risk Management Policy (the “*Policy*”) and apply to all third-party relationships entered into by FHI. These Procedures represent the minimum required activities in identifying, evaluating, establishing, monitoring, and terminating the third-party relationship and are in addition to any other requirements applicable to a particular third-party relationship.

2. Risk Rating Tiers

All third parties are categorized based on the inherent risk they pose to FHI (i.e., the risk posed by the third party if no controls or other mitigating factors were in place). The risk rating tiers are as follows: *High*, *Medium*, *Low*, and *Minimal*. For each non-exempt engagement with a third party, BUs must complete an Engagement Scope Assessment and any triggered risk reviews to determine the inherent AND residual risk ratings. The engagement’s risk ratings are the **high-water mark** of all required risk reviews. For example, if the Engagement Scope Assessment triggered a Compliance Review and Technology Review, where the inherent compliance risk rating is *Low* and the inherent technology risk rating is *Medium*, then the engagement’s overall inherent risk rating is *Medium*.

The inherent and residual risk ratings of a third party is a roll-up based on the **high-water mark** of associated active engagements. For example, if a third party is engaged with FHI through two inherently *Low*-risk engagements and one *High*-risk engagement, the third party’s inherent risk rating will be *High*.

Additionally, third parties can be designated as *Critical* or *Important* irrespective of risk rating if one or more business processes have a material reliance on the products/services provided by the third party (i.e., with required recovery objective of 24 hours or less for *Critical* and 48-72 hours for *Important*). The list of *Critical* and *Important* third parties are updated annually, up to one quarter after completion of the Business Impact Analysis (BIA) campaign (see Business Continuity Management Policy ([P 1797.00](#))). *Critical* third parties may require additional risk reviews and ongoing monitoring activities as per requirements defined by ETRM and Reviewers.

2.1 Risk Acceptance for Residually High-Risk Engagements

Third-party engagements assessed as residually *High* represent a potentially material exposure to FHI, and as such, require the Third-Party Manager (TPM) to carefully review the risks prior to engaging with the third party. Residually *High-Risk* engagements are subject to risk acceptance review and approval by the TPM’s Division/Group Manager and Enterprise Risk. Risk acceptance expirations must be monitored by the TPM, with timely extensions and renewals as needed.

2.2 Risk Rating Determination

Reviewers that designate third party inherent and residual risk ratings must have documented procedures on how risk ratings are determined and periodically review and update the rating methodology as needed to align with legal/regulatory expectations and FHI risk appetite.

3. Third-Party Review/Contacts

As of the last revision date of these Procedures, below are the primary contacts associated with the various reviews:

- Engagement Scope Assessment: ETRM team (etrm@fhib.com)
- Compliance Review: the applicable BU Compliance Officer/Coordinator (COC) and Corporate Compliance Division (CCD)/Tricia Fujikawa Lee. See Compliance Steering Committee Program ([P 1701.00](#)) for list of COCs
- Financial Viability Assessment: Credit Department/Rosemarie Cantoria and Eliza Young
- Contracts/Legal Review: designated BU Legal contact as per <http://bancnet/site/info/directories/legalcontacts.pdf>
- Insurance Review: Insurance Manager/Gwen McDonald (fhibinsurancereview@fhib.com)
- Security Review and Data Sensitivity & Risk Review: Vendor Security Review team (vendorsecurity@fhib.com);
- Technology: Cyber Architecture team (infosec@fhib.com)
- Subcontractor Risk Assessment: ETRM team (etrm@fhib.com)
- Report on Examination (ROE): To request a copy of an FFIEC Report of Examination (ROE), submit an [IT Service Portal](#) request. See Request for Report of Examination Procedures ([SP 4000](#)) for more details.

For any other questions, please contact ETRM at etrm@fhib.com.

4. ETRM System of Record

The Program must maintain FHI’s system of record (currently Archer) to assist with assessing inherent/residual risk, conducting due diligence, and monitoring, and tracking information about FHI third parties and engagements. Specific instructions for use of the ETRM system of record are included as Exhibit “A”.

5. Exempt Third Parties

An “*Exempt third party*” is a person or company who provides Product/Services to FHI that pose an insignificant amount of risk to FHI, and as such, may not trigger additional reviews by Reviewers with the exception of Legal and/or Insurance Reviews (see *Required Reviews and Triggers for Reviews* section in Section 8). Exempt third parties are still required to be recorded in the ETRM system of record upon onboarding and reviewed and updated as necessary at least every three years. Generally, the following categories of third parties are considered *Exempt*.

1. Wholly-owned subsidiaries of FHI, such as The Bankers Club, Inc.
2. A government entity providing generally available government services, such as issuing licenses or permits, maintaining registrations, filing documents.
3. Non-Vendor Third Parties that are not *Critical* or *Important* based on the annual BIA campaign.
4. A person or company who provides FHI with one or more of the following Products:
 - ATM installation, including installation, transportation and security
 - Credit Bureaus performing credit pulls¹
 - Crowd control services, such as special duty police officers
 - Entertainment for events
 - External copying services, such as HONBLUE
 - Financial Market Utilities such as SWIFT and Federal Reserve
 - Fitness classes or massage therapy
 - Food, beverages and related supplies
 - Membership organization services (No Bank info/PII involved)
 - Plant rentals or purchases
 - Postage and shipping charges, such as USPS, FedEx and UPS
 - Print or airing of prepared (FHI-created) advertisements
 - Printed publications and subscriptions
 - Supplies (as defined in and covered by [SP 950.10](#)), uniforms, holiday decorations, fitness equipment and trophies
 - Travel and lodging
 - Tuition or registration fees for classes and seminars that are open to attendees outside FHI
 - Utility payments and charges from sole-source, municipal or regulated providers, such as Hawaiian Electric, Board of Water Supply, Hawaiian Telcom
 - Vehicle maintenance, repair or fuel

6. Third-Party Lifecycle

The third-party lifecycle consists of four phases: (1) due diligence; (2) contract negotiation; (3) ongoing monitoring; and (4) termination:

DUE DILIGENCE	CONTRACT NEGOTIATION	ONGOING MONITORING	TERMINATION
<i>The first step with engaging a third-party is an Engagement Scope Assessment to identify the scope of third-party services provided to FHB and related potential risks with the engagement.</i> <i>Based on the scope of the engagement, the relevant subject matter experts (SMEs) are included in the due diligence process to perform their respective reviews of the third-party and engagement, including Legal, Compliance, Insurance, Credit/Finance, Technology, and Security.</i>	<i>This activity focuses on finalizing the written agreement between FHB and the third-party that governs the expectations and obligations of the engagement for both parties.</i> <i>Based on the negotiated contract, both parties are in full agreement on resulting limitations and consequent risks and allow FHB to plan for compensating measures as appropriate.</i>	<i>This ongoing activity focuses on maintaining awareness of the third-party's risk and performance, and its ability to meet contractual obligations, which enables FHB to systematically identify, escalate, and respond to significant issues or concerns throughout the duration of the engagement.</i>	<i>This activity focuses on terminating the engagement and/or the overall relationship with the third-party in an efficient manner to ensure effective transition or termination of services, managing costs and fees associated with the termination, and managing the impacts of the termination.</i>

¹ All other Credit Bureau activities require completion of Engagement Scope Assessment to determine risk level.

7. Phase 1: Due Diligence

7.1. Overview

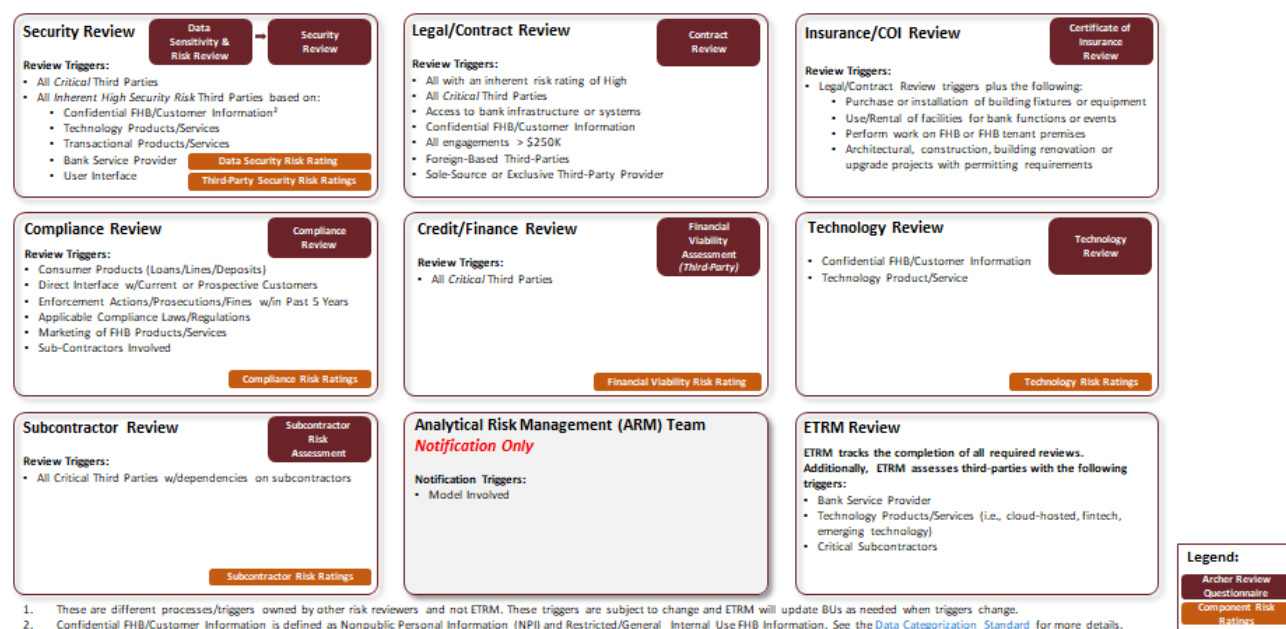
The first phase of the ETRM process consists of conducting due diligence on the third party/engagement. Adequate due diligence must be conducted on all third parties prior to selection and contracting. During this phase, the BU will obtain information about the third party with a focus on (1) the third party's ability to perform the proposed contractual obligations; and (2) the level of risk associated with the proposed contractual relationship with the third party/engagement. Due diligence involves analyzing information regarding the third party that will allow FHI to make an informed decision about whether a relationship with a specific third party is advisable and likely to accomplish FHI's objectives. The nature and extent of due diligence will vary depending on the inherent risk level associated with the third party for the Product/Service.

At the onset of a third-party lifecycle, business units must determine whether the third-party relationship meets the overall strategic goals, objectives, risk appetite, risk profile, and broader FHI policies. Once a third party is determined, BUs must identify and assign an officer of FHI as the third-party manager responsible for managing, mitigating, and overseeing the third-party relationship.

Business units will complete an inherent risk assessment in the ETRM system of record which considers potential third-party risks across multiple risk areas (i.e., Technology Risk, Security Risk, Compliance Risk, and Financial Viability Risk). The inherent risk rating will provide an indication of third-party risk involved prior to any efforts to reduce or mitigate the risk as a rating of High, Medium, Low, or Minimal. Business units and/or risk teams conduct a residual risk assessment in the ETRM system of record based on the criticality and other factors to determine the reduction or mitigation of the inherent risk for the third party. The outcome of the residual risk assessment will be a residual risk rating of High, Medium, or Low. The residual risk rating will help guide FHI in determining the remaining risk for any given third-party relationship after due diligence and/or controls have been implemented.

7.2. Cataloging the Third Party and Engagement

TPMs are responsible for adding and maintaining information about prospective and active third-party engagements in the ETRM system of record, as the system of record is leveraged across relevant subject matter experts (SMEs)/Reviewers are included in the due diligence process to **perform their respective reviews, including Legal, Compliance, Insurance, Credit/Finance, Technology, and Vendor Security Review**:



7.2.1. Required Review of Critical Subcontractors

Subcontractors are 4th/Nth parties that an FHI third party depends on to deliver the Product/Service to FHI. For example, a third party providing a software product to FHI may be hosted in a separate infrastructure provided by another organization (e.g., cloud service provider). The third party is dependent on the infrastructure provider to host its platform, and therefore, considered a subcontractor dependency to FHI.

A Subcontractor Risk Assessment is required for all third parties designated as *Critical* with subcontractor dependencies such that the Product/Service provided to FHI will be materially disrupted if the subcontractor

were unavailable. The assessment is completed by the TPM and reviewed by ETRM during onboarding of the Engagement and annually thereafter.

7.2.2. Obtain Documentation from the Third Party

This process involves data collection and retention in the ETRM system of record and should be completed prior to contract signing (for lower risk rated third parties that may not have a contract; this should be completed prior to engaging the third party). It is the responsibility of the TPM to make certain that all relevant information is obtained from the third party and reviewed, and to explain why certain required information was not obtained and why it may not be relevant. In addition, some documentation requirements may be substituted if the nature of the control is captured in a provided document. For example, if the provided SOC report includes DR/BCP controls and recent testing results, the DR/BCP policies/procedures and test results may not need to be obtained. The following documentation must be obtained from the third party based on Reviewer requirements:

Third-Party-Provided Documentation	Security Review	Legal/Contract Review	Insurance Review	Compliance Review	Credit/Financial Review	Cyber Architecture Review	BCM Review*
Independent Controls Assessment as applicable (SOC 2 Type II, ISO 27001, etc.)							
Payment Card Industry Report on Compliance as applicable (PCI RoC)							
Penetration Test and Remediation Summary (if available)							
Vendor Assessment Questionnaire if available (e.g., Standardized Information Gathering (SIG) questionnaire or comparable questionnaire)							
Third-Party Contract Documents							
Certificate of Insurance (COI)							
Fines, Penalties, or Sanctions Related Documentation (as needed)							
Third-Party Compliance with Applicable Lending Laws/Regulations (if available)							
Third-Party Fair Lending Policies/Procedures (if available)							
Third-Party Privacy Policy (if available)							
Financial Statements (past 3 years)							
System/Network Architecture Diagram							
Business Continuity/Disaster Recovery Test Results and Remediation Summary (if available)							

Legend:

*Depending on scope and contractual terms of the engagement

As requested by reviewing party

Additionally, BUs may be required to obtain the following:

- **OFAC check results:** via BSA function.
- **Report of Examination (ROE)** (for *Critical/High-Risk* third-parties that are examined by federal banking agencies): via Enterprise Technology Risk function.

7.2.3. Obtain the Required Approvals for Third-Party

All required reviews for the Engagement must be completed and approved by the TPM prior to engaging with the third party. Approvals must be maintained in the ETRM system of record for historical reference purposes.

8. Phase 2: Contracting

8.1. Overview

Contracting consists of the TPM negotiating and executing a contract for the approved third-party Engagement. The contract should clearly identify the third party's obligations to FHI and mitigate, to the extent possible, the risks associated with the third-party relationship. Key contract topics include scope of services, term, compensation, service level agreements, performance benchmarks, complaint management and reporting, responsibility for compliance with applicable laws and regulations, evaluation of compliance with laws and other contract requirements, frequency of compliance performance reporting, human resource management, data confidentiality, information security, reporting of intrusions, physical security, ownership and license, business continuity and disaster recovery planning and testing, right to audit and require remediation, default and termination, early termination rights, conversion and deconversion assistance, return of confidential information, limitations on assignment, insurance requirements, requirements for foreign-based third parties or subcontractors, indemnification, dispute resolution, and choice of law and venue. The ideal way to comply with future due diligence requirements is to add the obligations of the third party into the contract (including in the contract requirements for the third party to comply/produce the documents that are needed by a certain date or based on a specific frequency).

8.2. Specific Actions

The BU's obligations during the Contracting phase will depend on whether Legal is involved with reviewing and revising the third-party contract. Each scenario is discussed below.

8.2.1. Legal is Involved



Notify and consult with Legal if any of the following apply:

- o Third party has an ETRM inherent risk rating of High.
- o Third party provides critical services or has been designated as a critical third party.
- o Third party has access to the bank infrastructure or systems (including the bank's servers, whether owned, leased, or licensed by bank).

- Third party may receive, store, access, transmit or perform transactions on customer, including “sensitive customer information”, proprietary, sensitive, or confidential information.
- Third-party is a sole or exclusive provider of the Products or services to FHI.
- Third-party is foreign based, including those providing Products or services outside of the U.S.
- \$250,000 or more will be paid to the third party over the initial term of the contract.

Legal has the primary responsibility for drafting or reviewing and revising the third-party contract. However, the BU will have more information about the business points and operational needs than Legal. As a result, the BU is responsible for ensuring that all business points and operational needs are accurately reflected and addressed in the contract. (See [Section 8.2.3](#) below for addition required actions.)

8.2.2. Legal is Not Involved

For third parties or Engagements that do not meet the criteria specified in [Section 8.2.1](#), the BUs are not required to consult with Legal and the BU has the primary responsibility for the third-party contract. However, the BU may ask Legal to draft or review and revise the contract if it believes that Legal's involvement is appropriate or beneficial.

8.2.3. Insurance Risk Manager is Involved



Notify and consult with the Insurance Risk Manager for review or preparation of insurance requirements if any of the following apply:

- Legal review is required by these Procedures (see [9.2.1. Legal is Involved](#) above);
- FHI is purchasing building fixtures or equipment or the third-party or its employees, subcontractors or agents is installing such fixtures or equipment;
- FHI is using or renting facilities for bank functions or events;
- The third-party or its employees, subcontractors or agents will enter or perform work on FHI or FHI tenant premises; or
- The services are for architectural, construction, building renovation or upgrade projects.

The Insurance Risk Manager must be consulted with sufficient time prior to contract execution to allow the parties to negotiate insurance provisions. Insurance review for architectural, construction, building renovation or upgrade projects should be made prior to the release of any request for proposals.

8.2.4. Insurance Risk Manager is not Involved

Certain exceptions apply for engagements/third parties that have standardized contract and insurance terms, where the Bank applies the same insurance terms to multiple third parties engaging in similar types of work. The BUs are not required to consult with the Insurance Manager and the BU has the primary responsibility for the contractual insurance requirements **only** for the following third parties:

- External Legal Counsel (standardized Outside Counsel Guidelines apply);
- Various Bank Properties engagements including those that do not require on-premise access or where the on-premise access is limited and not related to architectural, construction, building renovation or upgrade projects (e.g., various trade work, handyman, janitorial services, etc. where the Insurance Requirements for Maintenance and Repair would apply).

8.2.5. Certificate of Insurance Review is Required for Ongoing Monitoring

Where insurance terms are contractually required and the third party has an inherent risk rating of medium or high, the Insurance manager will complete an annual review of the third party's Certificate of Insurance.

8.2.6. Certificate of Insurance Review is Not Required for Ongoing Monitoring

The Insurance Manager is not required to review the third party's Certificate of Insurance if the third party has an inherent risk rating of low/minimal. Furthermore, as noted in section 8.2.4, where the Bank applies the same insurance terms to multiple third parties engaging in similar types of work (i.e., external legal counsel and various bank properties engagements), the Insurance Manager is not required to review the third party's Certificate of Insurance.

8.2.7. OFAC Screen Requirements

First Hawaiian Bank complies with all United States laws, regulations, and orders related to doing business with, maintaining accounts for, or handling transactions or monetary transfers for foreign countries, nationals, businesses, and other entities listed on OFAC's Specially Designated Nationals List (“SDN list”), Consolidated Sanctions Lists (Non-SDN List) as well as other watch lists. Prior to contract execution with a new third party, the third party must clear an OFAC, FHI's Have-No-Dealings and other sanctions list screen (collectively, “OFAC Screen”). The BSA Division manages the [OFAC Compliance Program](#) and performs weekly OFAC screens against all active and onboarding third parties maintained in ETRM system of record. **BUs are responsible for ensuring third parties clear the OFAC Screen prior to contract execution.** Refer to the [BSA Home Page](#) for details and BSA contact information.

8.2.8. Notification Requirement to FDIC of Bank Services

“Bank Service” means:

- Check and deposit sorting and posting (including online banking),
- Computation and posting of interest and other credits and charges,
- Preparation and mailing of checks, statements, notices, and similar items (including electronic statement delivery),
- Any other clerical, bookkeeping, accounting, statistical, other similar functions such as data processing, internet banking, or mobile banking services performed for a depository institution.

If the third party is providing any “Bank Service” (as defined above), ETRM with the help of the BU must notify the Federal Depositary Insurance Corporation (“FDIC”) of such third-party relationship within thirty (30) days after the earlier of (1) entering into the contract, or (2) the third-party’s performance of such services. The BU must notify ETRM within the specified timeframe, and ETRM then submits the notification to the FDIC.

9. Phase 3: Monitoring

9.1. Overview

Monitoring consists of the TPM monitoring and overseeing the third party’s performance of its obligations under the contract. The TPM must validate and update the information collected in due diligence and obtain updated information about the third party as necessary to determine whether the risk level associated with the relationship has changed. **Any issues identified during the monitoring and oversight process must be promptly evaluated and, if necessary, addressed by the TPM.** The extent of monitoring and oversight will vary depending on the nature of the third party/engagement and the associated degree of risk. The scope and frequency of monitoring may need to increase as changes occur to the third party and Product/Services being provided or events occur negatively impacting the third party or its Product/Services. General examples of monitoring activities include:

- verifying the information gathered in due diligence to ensure the level of risk has not changed;
- verifying that the third party is meeting the terms of the contract and business needs;
- obtaining required certificates of insurance annually and/or at each policy expiration;
- monitoring complaints;
- call monitoring and review of scripts;
- reviewing the contract to determine if the terms still meet business needs;
- monitoring of any subcontractors;
- confirming the accuracy of invoicing;
- evaluating progress of any required remediation activities; and
- periodic review of third-party key controls (such as information security, business continuity, physical security and regulatory compliance) and procedures to ensure compliance with laws and regulations, and assessing third-party’s financial condition.

Certain triggering events impacting the third party or its Product/Services could change the risk level of a third-party relationship. Such triggering events may include: organizational changes such as mergers, customer or key staff attrition; changes in law or regulations; fraud, theft or security events; litigation involving third party; natural disasters or terrorist acts impacting third party; changes in the use of third party’s products and services; notification of regulatory findings and recommendations (such as FFIEC Reports of Examination) or consent orders (collectively, “ROEs”); and critical incidents that occur with third party. If such a triggering event occurs, BUs should promptly reassess the third-party relationship.

For critical and high inherent risk third parties, the TPM should submit an [IT Service Portal](#) to request a copy of an FFIEC Report of Examination (ROE) for the third party. See Request for Report of Examination Procedures ([SP 4000](#)) for more details. If an ROE exists, the BU must promptly notify ETRM of any ROEs and upload the document to the ETRM system of record.

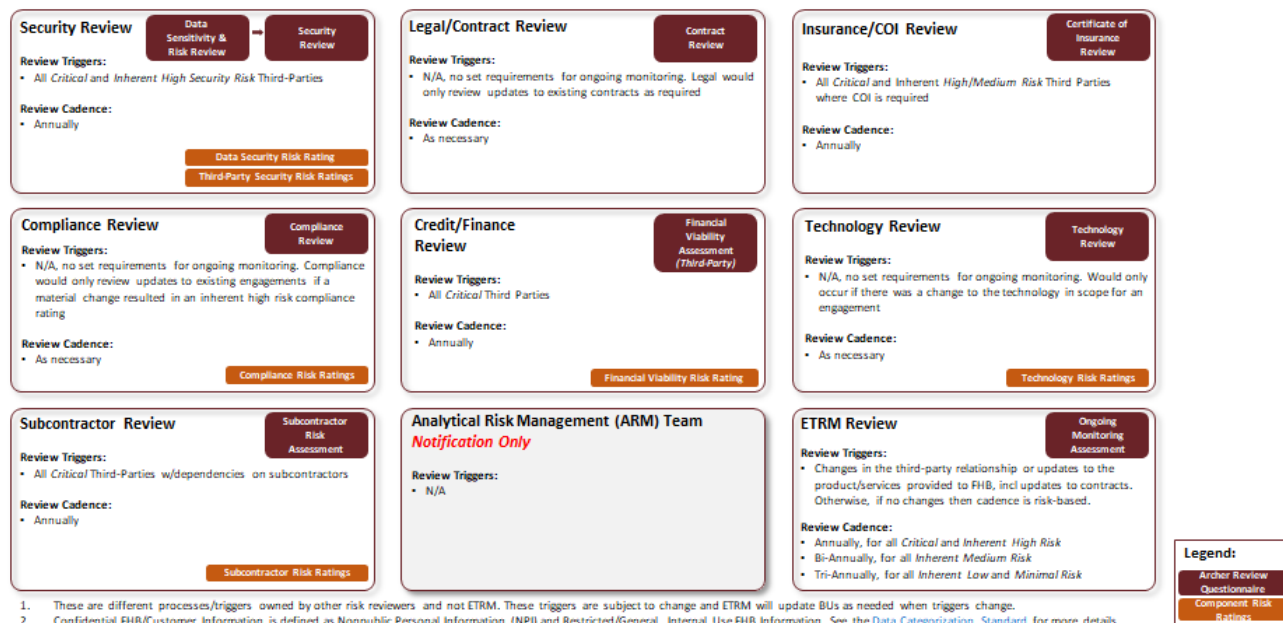
9.2. Specific Actions

ETRM will notify the TPM when periodic monitoring needs to be completed. Review cycles are set according to risk tier at:

- Every 1 year for critical and high inherent risk third parties
- Every 2 years for Medium inherent risk third parties
- Every 3 years for Low/Minimal inherent risk third parties

The Ongoing Monitoring Assessment is intended as a starting point for conducting monitoring. Additional monitoring may be necessary to allow FHI to accurately and thoroughly evaluate whether (1) the third party is meeting its obligations under the contract and (2) the risk level associated with the contractual relationship has changed. It is the responsibility of the TPM to make certain that appropriate information is obtained from the third party and evaluated.

It is at the discretion of the TPM to determine the appropriate additional monitoring activities (such as on-site third-party visits). The triggers and requirements for ongoing monitoring reviews and review cadence are as follows:



The review triggers and cadence specified for ongoing monitoring are owned by the Reviewers and not ETRM (with the exception of the Subcontractor Review and Ongoing Monitoring Assessment). The requirements are subject to change and ETRM will update BUs as needed.

All required documentation from the third party must be uploaded to the ETRM system of record. Any issues identified during the monitoring and oversight process must be promptly evaluated and, if necessary, addressed by the BU. Monitoring results must be reviewed and approved by the TPM.

9.3. Problems with a Third Party

If monitoring identifies any material concerns, including any ROEs, about the third-party's performance of its obligations under the contract or an increase in the risk level associated with the third-party relationship, the BU must promptly notify ETRM. *When in doubt, notify.* Notification should at minimum include a description of the incident(s) causing the concern, impact, relevant dates, whether customer information is involved and any other relevant details. ETRM will confer with oversight partners on whether the concern needs to be reported to a management committee or board committee. The TPM will also be responsible for making certain that appropriate action is taken to address the concern.

9.4. Third-Party Complaints

For third parties that have direct contact with FHI customers as part of promoting or providing a Bank product/service for, or on behalf of, FHI, the BU must monitor customer complaints and promptly document, report, track and resolve complaints regarding the third party and the associated product/service provided to FHI. The identification of complaint trends may be a leading indicator of third-party issues that need to be addressed. The BU must ensure that the third party:

- Has an established process for communicating any customer complaints, concerns, or solicitation preferences to FHI and any actions third party may have taken to address an issue;
- Promptly reports any customer complaints, concerns or solicitation preferences to the TPM or other designated employee;
- Has an established process for FHI to monitor its calls, review and approve scripts, type of calling, and decision or logic models; and
- Ensures appropriate language is incorporated into the contract holding third-party accountable and that support such requirements.

9.5. Critical Third-Party Performance Monitoring Requirements

For third parties that are designated as *Critical*, the associated critical engagement will have additional ongoing monitoring requirements to ensure their performance either continues to meet contractual terms or otherwise maintain their services to an agreed upon level to minimize operational disruption to FHI.

9.5.1 Defining Performance Metrics

Performance monitoring is tracked via defined metrics for each Critical third-party engagement:

- Qualitative metrics capture the health of the relationship with the third party, e.g., with the assigned account manager and/or support team, responsiveness to inquiries and required due diligence reporting requirements.
- Quantitative metrics capture specific aspects of the product/service as part of contractual requirements, e.g., system uptime, closure of support tickets within defined service level agreement (SLA), and number of material outages. Quantitative metrics must be provided for third-party engagements involving Critical applications or IT infrastructures where SLAs are contractually defined.

For any newly designated third parties deemed as *Critical*, the TPM must define and provide performance metrics within one quarter of designation.

9.5.2 Missed Performance Targets

Failed performance metrics represent a potential for or an actual disruption to critical FHI business operations, and as such, must be tracked and reported to allow for appropriate risk management discussions and decisions. For *Critical* applications or IT infrastructures where SLAs are contractually defined, performance below 99% is considered a guideline breach, and performance below 95% is considered a breach of an availability risk metric as defined in the Enterprise Risk Appetite Framework ([FHI-003-RMG](#)) and are reported to the Enterprise Risk Committee/Board Risk Committee (ERC/BRC) accordingly.

9.5.3 Tracking and Reporting

The ETRM Team is responsible for tracking and reporting on the performance metrics to the BRC and TCD on a quarterly basis. TPMs must provide performance metrics for *Critical* third parties on a quarterly basis to ETRM to satisfy the tracking and reporting requirements.

10. Phase 4: Termination

A third-party engagement may be terminated for various reasons, including expiration or satisfaction of the contract, for convenience (desire to seek an alternate third-party product/service, bring the activity in-house or discontinue) or breach of contract.

BUs are responsible for carefully planning and terminating in an efficient manner, whether the activities are transitioned to another third party, performed by FHI, or discontinued. Without careful planning, consequences include: an inability to adequately provide services to customers; loss or compromise of valuable data and records; customer dissatisfaction; difficulties transitioning services; and termination fees. BUs should have a plan to transition to another third party or bring the service in-house if there are no other viable third parties.

BUs should carefully review the contract prior to termination, follow all contractually mandated procedures and provide all required notifications. BUs should notify and consult with ETRM and Legal prior to termination.

11. Additional Requirements for Third parties Who Are Individuals

11.1. Criminal Background Checks and Prohibited Conduct

There are additional requirements if the third party is an individual and participates directly or indirectly in the conduct of the affairs of the bank. [Section 19 of the Federal Deposit Insurance Act \("Section 19"\)](#) prohibits the bank from hiring or permitting direct or indirect participation in the bank's affairs by someone who has been convicted of a crime of dishonesty or breach of trust or money laundering. Section 19 also covers persons who have entered pretrial diversion programs in lieu of conviction. For purposes of this section, conviction, or pretrial diversion with respect to these types of crimes is referred to collectively as "*Prohibited Conduct*."

This prohibition applies to anyone who "participates, directly or indirectly, in the conduct of the affairs" of the bank. A third party can be covered if the third party: (1) knowingly or recklessly participates in violations, unsafe, or unsound practices, of breach of fiduciary duty which are likely to cause significant adverse effects on the bank; or (2) influences or controls the management or affairs of FHI. If a third party falls within one of those categories, the BU must take reasonable steps to avoid or cease contracting with a third party who has engaged in Prohibited Conduct. While Section 19 only applies to individuals, when hiring any entity as a third party there may be situations where the key employees of the third party should be screened before working on the FHI matters.

12. Third-Party Manager Approval of Payments to Third Parties; Emergencies

The TPM or such other qualified person of equal or higher level who is designated by the BU or Group level manager must approve all payments to any third party by confirming that third-party expenses (AC-112) to be paid conform to these Procedures. No payments will be made without the required TPM or qualified designee approval or confirmation.

In emergency situations where third parties need to be paid and TPMs are unable to certify compliance with these Procedures because full compliance is not possible, e.g., following a storm, the electricity goes out and the ETRM system of record is not available, Division Managers or above may authorize exception to this requirement. Following the emergency, as soon as practicable, TPMs should document the emergency and the reason for the exception and attach to the engagement in the ETRM system of record and then comply with these applicable Procedures.

13. Documentation and Retention of Documents

Actions taken in accordance with these Procedures should be documented in the ETRM system of record, such as the originally executed third-party contract. All completed due diligence, monitoring, approvals, and all other supporting documentation, must be maintained in the ETRM system of record and retained for the period required by FHI's applicable record retention policy. TPMs are responsible for and have effective control of their respective engagements.

14. Confidentiality

If a contract contains confidentiality provisions, those obligations owed by FHI must be observed by the TPM responsible for the specific third-party/engagement relationship and for communicating such obligations to others as applicable. For example, if another BU requests a copy of a third-party/engagement contract containing requirements that FHI keep confidential the terms of that contract, the TPM responsible for that contract should inform the requesting BU regarding the confidentiality requirement and take steps to safeguard the confidential terms.

15. Procedural Compliance Monitoring

ETRM will monitor compliance to these Procedures by: (1) confirming that the requirements of these Procedures have been satisfied for new and existing third parties/engagements using a risk based approach; (2) confirming annually that the requirements of these Procedures have been satisfied for all active *Critical* and *High* risk relationships; (3) tracking and reporting any non-compliance with required third-party due diligence reviews to TCD/BRC; and (4) reviewing payment information at least annually to identify potential third parties or Product/Services that should be included in the Program.

16. Exceptions

All employees are responsible for identifying situations that would result in an exception to these Procedures or any applicable laws and regulations. Those exceptions should be reported promptly, documented, reviewed, and approved at a level of the organization that is commensurate with their determined materiality. In case of doubt, employees should refer to the owner of these Procedures and IT Governance for guidance, including whether further escalation and risk acceptance (i.e., IT Governance Exceptions Tracking or Technology Variance) is appropriate.

Failure to report exceptions or comply with these Procedure can result in disciplinary actions up to and including termination of employment for employees or termination of contracts for contractors, partners, consultants, and other entities. Legal actions also may be taken for violations of applicable regulations and laws.

List of Exhibits

[Exhibit "A"](#) Archer Procedures

Summary of Revisions

Date	Description of Change
March 1, 2018	New Standard Procedure
March 1, 2021	Revised EVRM procedure
December 23, 2022	Revised to include Policy update for third-party, updated definitions, annual review of exempt vendors, and archiving of exempt vendors
February 26, 2025	- Revised to reflect <i>Archer</i> as the ETRM system of record. - Revised to reflect updated procedures and detailed workflows in <i>Archer</i>. - Revised to retire <i>Exempt</i> category and replace with <i>Minimal</i> risk. - Revised to retire <i>Very High</i> risk tier and combined with <i>High</i> risk tier.

	• Revised to include criticality rating as determined by BCM Program's Business Impact Analysis (BIA) process. • Revised to add third-party residual risk ratings (in addition to inherent risk ratings). • Revised and expanded ETRM roles and responsibilities to include Reviewers. • Added new performance monitoring requirement for <i>Critical</i> third-parties. • Added new requirement for Subcontractor Risk Assessment for critical subcontractors. • Added new requirement for Ongoing Monitoring Assessment for all active third-party engagements.
December 30, 2025	• Removed roles/responsibilities and definitions, which are now covered in the ETRM Policy. • Added new Insurance Risk Manager is not Involved sections. • Retired Enterprise Third-Party Risk Management Standard Procedure SP 1053.02 and included the applicable requirements into this document.